API Revision Notebook: The BrainSAIT Reference

API Revision Notebook: The BrainSAIT Reference

Edition: v1.0 · 21 July 2026

Author: Dr. Mohamed El Fadil Abuagla — Founder & CEO, BrainSAIT LTD

Enterprise OID: 1.3.6.1.4.1.61026

License: CC BY-NC-SA 4.0

Classification: Premium Strategic Asset — Marketplace Listing

---

ملخص تنفيذي

دفتر مراجعة API هو المرجع التشغيلي اليومي لجميع واجهات برمجة التطبيقات في منظومة برين سايت. يحتوي على أنماط التصميم، معايير الأمان، وأمثلة النشر.

Executive Summary

The API revision notebook is the daily operational reference for every API in the BrainSAIT ecosystem. It documents design patterns, security standards, and deployment examples.

API Surface Map

Surface	Port	Purpose
Hub	9200	Event bus, orchestration
API	9300	Public REST API
Dashboard	9400	Admin UI JSON
Store	9500	Marketplace JSON
Profile	9600	Identity / SSO
Portal	9610	Customer portal
Notebooks	9700	Knowledge capsules

All services bind to `127.0.0.1`; nginx terminates public HTTPS and proxies upstream.

Design Standards

Versioning

Every endpoint carries a major version in the path: `/api/v1/...`. Breaking changes get a new major; additive changes are minor and don't change the path.

Authentication

- **HMAC** for webhooks (no replay, shared secret).
- **Bearer token** for user-facing endpoints.
- **API key + signature** for partner integrations.

The hub's `POST /purchase` requires a valid key (else 401). The Telegram webhook requires HMAC (else 403). Both proven live in `scripts/audit.py`.

Idempotency

Every mutating endpoint accepts an `Idempotency-Key` header. Same key + same payload = same response, even on retry.

Rate Limiting

Per-key buckets. Default: 1000 req/hour for partners, 100 req/minute for unauthenticated probes.

Response Shape

```json
{
"ok": true,
"data": { ... },
"meta": { "request_id": "...", "ts": "..." }
}
```

Errors:

```json
{
"ok": false,
"error": { "code": "...", "message": "..." }
}
```

Never stack-trace in production responses.

Security Standards

- **TLS only.** No plaintext HTTP for any public endpoint.

- **Loopback binding.** Money-path services bind `127.0.0.1`; nginx fronts them.
- **HMAC verification on webhooks.** Reject unsigned, reject replayed.
- **Input validation at the edge.** No trusting user input into internal services.
- **Secrets in 600-mode files.** Never world-readable, never committed.
- **Audit logging on every mutating endpoint.** Reconstructable trail.
- **No PII in logs.** Redact; pseudonymize; hash where needed.

FHIR R4 Compliance

Clinical APIs expose FHIR R4 resources. Each resource carries:

- Saudi extension URLs in `meta.profile`.
- Validated against a frozen test suite before each release.
- Versioned with a `meta.versionId` per resource.

Bulk export is implemented per the FHIR bulk-data spec.

NPHIES Integration

Claim submission follows the CHI NPHIES profile. The integration pattern:

```
EHR → ClaimLinc (BrainSAIT) → NPHIES Gateway → Payer
                ↑
        Validation suite (CI)
```

ClaimLinc rejects claims with known-deny patterns before submission; the rejection is logged with reason code and recommended correction.

Deployment Pattern

Every service follows:

- **Build** → Docker image tagged with semver.
- **Test** → live boot against `/health` and one real endpoint.
- **Audit** → `scripts/audit.py` exits 0.
- **Deploy** → systemd `--user` unit with `Restart=always`.
- **Verify** → curl from outside nginx, not from inside the service.

Step 5 is non-negotiable. A healthy `/health` from the service does not prove public reachability.

Observability

- Structured logs to JSON.
- Metrics endpoint on `/metrics` (Prometheus format).
- Traces via OpenTelemetry when present.
- Auto-heal script runs every 5 minutes; on detection of a service down, it restarts the systemd unit and re-verifies.

Error Handling

- 4xx for caller errors. Include `code` and `message`.
- 5xx for internal errors. Include `request_id`; never include stack traces.
- All 5xx trigger an alert via the auto-heal script.

Backwards Compatibility

- Major version bump requires a 6-month deprecation window for the previous version.
- Sunset endpoints respond with `410 Gone` after the window.
- A `Sunset` HTTP header announces the date.

Live Status (2026-07-21)

Verified by `scripts/audit.py`:

```
hub (9200): POST /purchase → 401 without key, 200 with key ✓
api (9300): GET / → 200 ✓
dashboard (9400): GET / → 200 ✓
store (9400 / JSON): GET /api/catalog → 200, all products Article-12 compliant ✓
profile (9600): GET /health → 200 ✓
portal (9610): GET /portal → 200, GET /api/profile → 401 ✓
notebooks (9700): GET /health → 200 ✓
```

Public via nginx + Cloudflare:

```
brainsait.de → 200
market.brainsait.de → 200 (with JSON-LD + ecosystem nav)
notebooks.brainsait.de → 200
brainsait.de/governance/ → 200
```

Appendix: The Auditor

The operational definition of "this API is healthy" is the auditor. Run it before every deploy; run it after every deploy; run it on a daily cron. The auditor's exit code is binding.

```bash
python3 ~/.hermes/brainsait/scripts/audit.py
echo "exit=$?" # 0 = compliant, 1 = blocking failure
```

© 2024-2026 BRAINSAIT LTD · Dr. Mohamed Elfadil Abuagla · CC BY-NC-SA 4.0

Enterprise OID: 1.3.6.1.4.1.61026 (IANA)

© 2024-2026 BRAINSAIT LTD — Dr. Mohamed Elfadil Abuagla · CC BY-NC-SA 4.0 — © 2024 BRAINSAIT LTD, Dr. Mohamed Elfadil Abuagla

Enterprise OID: 1.3.6.1.4.1.61026